

Web 應用程式報告

這份報告包含關於 Web 應用程式的重要安全資訊。

安全報告

這份報告是由 HCL AppScan Standard 所建立 10.11.0
掃描開始時間：2026/6/29 9:35:08

目錄

簡介

- 一般資訊
- 登入設定值

摘要

- 問題類型
- 有漏洞的 URL
- 修正建議
- 安全風險
- 原因
- WASC 威脅分類

依問題類型分組的問題

- SameSite 屬性不安全、不適當或遺漏的 Cookie²
- 加密的階段作業 (SSL) Cookie 中遺漏安全屬性²
- 缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭¹
- 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭¹
- 缺少或不安全的跨來源資源政策 (CORP) 標頭¹
- 偵測到隱藏目錄²
- 在CSP中未強制執行腳本中的可信類型¹
- 遺漏「Content-Security-Policy」標頭¹
- SameSite 屬性未受限制的 Cookie¹
- 在CSP中發現瀏覽器忽略的指令¹
- 找到可能的伺服器路徑揭露型樣¹
- 找到電子郵件位址型樣¹

如何修正

- SameSite 屬性不安全、不適當或遺漏的 Cookie
- 加密的階段作業 (SSL) Cookie 中遺漏安全屬性
- 缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭
- 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭
- 缺少或不安全的跨來源資源政策 (CORP) 標頭
- 偵測到隱藏目錄
- 在CSP中未強制執行腳本中的可信類型

- 遺漏「Content-Security-Policy」標頭
- SameSite 屬性未受限制的 Cookie
- 在CSP中發現瀏覽器忽略的指令
- 找到可能的伺服器路徑揭露型樣
- 找到電子郵件位址型樣

簡介

這份報告包含由 HCL AppScan Standard 執行 Web 應用程式安全掃描的結果。

中嚴重性問題：	7
低嚴重性問題：	4
參考資訊嚴重性問題：	4
報告中併入的安全問題總計：	15
掃描中探索到的安全問題總計：	15

一般資訊

掃描檔名：	03
掃描開始時間：	2026/6/29 9:35:08
測試原則：	Default
CVSS 版本：	3.1
測試最佳化等級：	快速
主機	prca.moenv.gov.tw
埠	443
作業系統：	不明
Web 伺服器：	不明
應用程式伺服器：	任何

登入設定值

登入方法：	已記錄的登入
並行登入：	已啟用
階段作業內偵測：	已啟用
階段作業內型樣：	
已追蹤或階段作業 ID Cookies：	
已追蹤或階段作業 ID 參數：	
登入序列：	

摘要

問題類型 12

目錄

問題類型		問題數目
中	SameSite 屬性不安全、不適當或遺漏的 Cookie	2
中	加密的階段作業 (SSL) Cookie 中遺漏安全屬性	2
中	缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭	1
中	缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭	1
中	缺少或不安全的跨來源資源政策 (CORP) 標頭	1
低	偵測到隱藏目錄	2
低	在CSP中未強制執行腳本中的可信類型	1
低	遺漏「Content-Security-Policy」標頭	1
參	SameSite 屬性未受限制的 Cookie	1
參	在CSP中發現瀏覽器忽略的指令	1
參	找到可能的伺服器路徑揭露型樣	1
參	找到電子郵件位址型樣	1

有漏洞的 URL 3

目錄

URL		問題數目
中	https://prca.moenv.gov.tw/	13
參	https://prca.moenv.gov.tw/bundles/jqueryval	1
參	https://prca.moenv.gov.tw/PublicInfo/GetSearchResult	1

修正建議 10

目錄

補救作業		問題數目
中	將「Cross-Origin-Embedder-Policy」(COEP) 標頭新增或修改為「require-corp」	1
中	新增 'Secure' 屬性至所有機密 Cookie	2
中	檢閱將 SameSite Cookie 屬性配置為建議值的可能解決方案	3
中	添加或修改「Cross-Origin-Opener-Policy」(COOP) 標頭為「same-origin」	1
中	添加或修改「Cross-Origin-Resource-Policy」(CORP) 標頭為「same-origin」或「same-site」	1
低	對禁止的資源發出「404 - 找不到」回應狀態碼，或將其完全移除	2
低	從網站移除電子郵件位址	1
低	請下載您的 Web 伺服器或 Web 應用程式的相關安全修補程式。	1
低	配置伺服器利用安全原則使用 "Content-Security-Policy" 標頭	1
低	配置正確值的Content-Security-Policy	2

安全風險 7

目錄

風險		問題數目
中	將 Cookie 限制為第一方或相同網站環境定義以預防 Cookie 資訊洩漏。如果沒有設置額外的保護措施（如反 CSRF 記號），攻擊者可以延伸為偽造跨網站要求 (CSRF) 攻擊。	2
中	有可能竊取在加密階段作業期間傳送的使用者和階段作業資訊 (Cookie)	2
中	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置	7
低	有可能擷取網站檔案系統結構的相關資訊，其可能會幫助攻擊者對映網站	2
低	有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等	3
參	將 Cookie 限制為第一方，或是將相同網站環境定義設定為 Strict，藉此預防 Cookie 資訊洩漏。	1
參	有可能擷取 Web 伺服器安裝架構的絕對路徑，其可能會幫助攻擊者展開進一步攻擊，以及取得 Web 應用程式之檔案系統結構的相關資訊	1

原因 6

目錄

原因		問題數目
中	SameSite 屬性不適當、不安全或遺漏的機密 Cookie	2
中	Web 應用程式會透過 SSL 傳送未受保護的 Cookie	2
中	不安全的 Web 應用程式設計或配置	7
低	使用不安全的方式配置 Web 伺服器或應用程式伺服器	2
參	SameSite 屬性未受限制的機密 Cookie	1
參	未安裝協力廠商產品的最新修補程式或緊急修復程式	1

WASC 威脅分類 2

目錄

威脅		問題數目
中	伺服器配置錯誤	3
中	資訊洩漏	12

依問題類型分組的問題

SameSite 屬性不安全、不適當或遺漏的 Cookie	
嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C
CVSS 3.1 評分：	4.7
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:U
CVSS 4.0 評分：	1.3
URL：	https://prca.moen.gov.tw/
實體：	_ga_T7Q7NPM8ET (Cookie)
風險：	將 Cookie 限制為第一方或相同網站環境定義以預防 Cookie 資訊洩漏。如果沒有設置額外的保護措施 (如反 CSRF 記號) ，攻擊者可以延伸為偽造跨網站要求 (CSRF) 攻擊。
原因：	SameSite 屬性不適當、不安全或遺漏的機密 Cookie
修正：	檢閱將 SameSite Cookie 屬性配置為建議值的可能解決方案

推論：回應包含 SameSite 屬性不安全、不適當或遺漏的機密 Cookie，這可能會導致 Cookie 資訊洩漏。如果沒有設置額外的保護措施，可能會衍生出偽造跨網站要求 (CSRF) 攻擊。

原始回應

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-YWlQnltnZEPIET2xmDJ0SR0yEM0yuTPwd8B9xtWSQR4=' 'strict-dynamic' https://www.google-analytics.com https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-YWlQnltnZEPIET2xmDJ0SR0yEM0yuTPwd8B9xtWSQR4=' https://fonts.googleapis.com https://cdnjs.cloudflare.com https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com https://www.googletagmanager.com https://www.google-analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src 'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for 'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer
```

```
'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:58:25 GMT
Content-Length: 35495
...
```

SameSite 屬性不安全、不適當或遺漏的 Cookie

嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C
CVSS 3.1 評分：	4.7
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:U
CVSS 4.0 評分：	1.3
URL：	https://prca.moenv.gov.tw/
實體：	_ga (Cookie)
風險：	將 Cookie 限制為第一方或相同網站環境定義以預防 Cookie 資訊洩漏。如果沒有設置額外的保護措施（如反 CSRF 記號），攻擊者可以延伸為偽造跨網站要求 (CSRF) 攻擊。
原因：	SameSite 屬性不適當、不安全或遺漏的機密 Cookie
修正：	檢閱將 SameSite Cookie 屬性配置為建議值的可能解決方案

推論：回應包含 SameSite 屬性不安全、不適當或遺漏的機密 Cookie，這可能會導致 Cookie 資訊洩漏。如果沒有設置額外的保護措施，可能會衍生出偽造跨網站要求 (CSRF) 攻擊。

原始回應

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-
tFR/3Lj03XmwudNM9RHc3XWBiz+B4BN9WBXaSJ9vfQ8=' 'strict-dynamic' https://www.google-analytics.com
https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-
tFR/3Lj03XmwudNM9RHc3XWBiz+B4BN9WBXaSJ9vfQ8=' https://fonts.googleapis.com https://cdnjs.cloudflare.com
https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com
https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com
https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-
analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src
'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for
'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer
'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:58:27 GMT
Content-Length: 35495
...
```


問題 1 / 2

目錄

加密的階段作業 (SSL) Cookie 中遺漏安全屬性

嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
CVSS 3.1 評分：	6.5
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	6.9
URL：	https://prca.moenv.gov.tw/
實體：	_ga_T7Q7NPM8ET (Cookie)
風險：	有可能竊取在加密階段作業期間傳送的使用者和階段作業資訊 (Cookie)
原因：	Web 應用程式會透過 SSL 傳送未受保護的 Cookie
修正：	新增 'Secure' 屬性至所有機密 Cookie

推論：AppScan 發現加密階段作業 (SSL) 使用不含 "secure" 屬性的 Cookie。

原始回應

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-ddPNRS/zWt5HmBFis25r9rdym5ATgY9vyl0TcWtigZ8=' 'strict-dynamic' https://www.google-analytics.com https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-ddPNRS/zWt5HmBFis25r9rdym5ATgY9vyl0TcWtigZ8=' https://fonts.googleapis.com https://cdnjs.cloudflare.com https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src 'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for 'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer 'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:58:25 GMT
Content-Length: 35495
...
```

問題 2 / 2

目錄

加密的階段作業 (SSL) Cookie 中遺漏安全屬性

嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
CVSS 3.1 評分：	6.5
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	6.9
URL：	https://prca.moenv.gov.tw/
實體：	_ga (Cookie)
風險：	有可能竊取在加密階段作業期間傳送的使用者和階段作業資訊 (Cookie)
原因：	Web 應用程式會透過 SSL 傳送未受保護的 Cookie
修正：	新增 'Secure' 屬性至所有機密 Cookie

推論：AppScan 發現加密階段作業 (SSL) 使用不含 "secure" 屬性的 Cookie。

原始回應

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-LjWOtp7swnd7Vz2aLlXwSlCQ52Gu3RO+U936bb6b1E=' 'strict-dynamic' https://www.google-analytics.com https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-LjWOtp7swnd7Vz2aLlXwSlCQ52Gu3RO+U936bb6b1E=' https://fonts.googleapis.com https://cdnjs.cloudflare.com https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src 'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for 'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer 'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:58:27 GMT
Content-Length: 35495
...
```

中 缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭 1

目錄

問題 1 / 1

目錄

缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭

嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
CVSS 3.1 評分：	4.2
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:P/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	2.3
URL：	https://prca.moenv.gov.tw/
實體：	prca.moenv.gov.tw (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置
原因：	不安全的 Web 應用程式設計或配置
修正：	將「Cross-Origin-Embedder-Policy」(COEP) 標頭新增或修改為「require-corp」

推論：AppScan 檢測到「Cross-Origin-Embedder-Policy」(COEP) 標頭要麼缺失，要麼設置為不安全的值。

原始測試回應：

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: application/octet-stream
Expires: 0
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-
iom42jJITbNFnKhZl5ggzvQDBWQOunkE6Da/uzEPqEg=' 'strict-dynamic' https://www.google-analytics.com
https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-
iom42jJITbNFnKhZl5ggzvQDBWQOunkE6Da/uzEPqEg=' https://fonts.googleapis.com https://cdnjs.cloudflare.com
https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com
https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com
https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-
analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src
'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for
'script'; trusted-types default dompurify app-policy goog#html;
Content-Disposition: attachment; filename*=UTF-
8''%E7%B3%BB%E7%B5%B1%E6%93%8D%E4%BD%9C%E8%AA%AA%E6%98%8E%E3%80%90%E8%AA%8D%E8%AD%89%E7%94%B3%E8%AB%8B%E7%AB%
AF%E3%80%91.pdf
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer
'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:51:37 GMT
Content-Length: 1380058
Set-Cookie:
__RequestVerificationToken=x7jyfPSaQrVszXTnL3SIHrmWSuw2ebCPYwRiS6cK2D0oeerMVo46jGNCKh8lcvLIrelkEISQYM-
UWUq2YBgcOdAtdrt42ERXwEi8f_6X9sKl1iL3IsH7PoL-i4i38H624BODvpI5AHd_fFCmkrJA8g2; path=/; s...
```

中 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭 1

目錄

缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭

嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
CVSS 3.1 評分：	4.8
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	6.3
URL：	https://prca.moenv.gov.tw/
實體：	prca.moenv.gov.tw (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置
原因：	不安全的 Web 應用程式設計或配置
修正：	添加或修改「Cross-Origin-Opener-Policy」(COOP) 標頭為「same-origin」

推論：AppScan 檢測到「Cross-Origin-Opener-Policy」(COOP) 標頭要麼缺失，要麼設置為不安全的值。

原始測試回應：

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-
LxPWVsOmKHa/V6RRjNSJyHB5gHrk2lwHcB9FUpnIPMU=' 'strict-dynamic' https://www.google-analytics.com
https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-
LxPWVsOmKHa/V6RRjNSJyHB5gHrk2lwHcB9FUpnIPMU=' https://fonts.googleapis.com https://cdnjs.cloudflare.com
https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com
https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com
https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-
analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src
'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for
'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer
'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:35:44 GMT
Content-Length: 71057
...
```

中 缺少或不安全的跨來源資源政策 (CORP) 標頭 1

目錄

問題 1 / 1

目錄

缺少或不安全的跨來源資源政策 (CORP) 標頭

嚴重性：	中
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
CVSS 3.1 評分：	4.8
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	6.3
URL：	https://prca.moenv.gov.tw/
實體：	prca.moenv.gov.tw (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置
原因：	不安全的 Web 應用程式設計或配置
修正：	添加或修改「Cross-Origin-Resource-Policy」(CORP) 標頭為「same-origin」或「same-site」

推論：AppScan 檢測到 "Cross-Origin-Resource-Policy" (CORP) 標頭要麼缺失，要麼設置為不安全的值。

原始測試回應：

```
HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-of4h8ZnEeOKpa+b/jCI5FGPL8028uu0UphQKaYJKUp4=' 'strict-dynamic' https://www.google-analytics.com https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-of4h8ZnEeOKpa+b/jCI5FGPL8028uu0UphQKaYJKUp4=' https://fonts.googleapis.com https://cdnjs.cloudflare.com https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src 'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for 'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer 'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:51:37 GMT
Content-Length: 7132
Set-Cookie:
__RequestVerificationToken=x7jyfPSaQrVszXTnL3SIHrmWSuw2ebCPYwRiS6cK2D0oeerMVo46jGNCKh8lcvLIrelkEISQYM-UWUq2YBgC0dAtdrt42ERXwEi8f_6X9sKl1iL3IsH7PoL-i4i38H624BODvpI5AHd_fFCmkrJA8g2; path=/; secure; HttpOnly; SameSite=Strict
...
```

問題 1 / 2

目錄

偵測到隱藏目錄

嚴重性：	低
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
CVSS 3.1 評分：	3.7
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	6.3
URL：	https://prca.moenv.gov.tw/
實體：	downloads/ (Page)
風險：	有可能擷取網站檔案系統結構的相關資訊，其可能會幫助攻擊者對映網站
原因：	使用不安全的方式配置 Web 伺服器或應用程式伺服器
修正：	對禁止的資源發出「404 - 找不到」回應狀態碼，或將其完全移除

推論：此測試嘗試檢測伺服器上的隱藏目錄/檔案。回應狀態為 200 OK 或 403 Forbidden。狀態 200 表示測試成功檢索所要求的目錄/檔案的內容。狀態 403 表示它的存在，即使不允許存取。

原始測試回應：

```
...

Sec-Fetch-Dest: script
Referer: https://prca.moenv.gov.tw/
Accept-Encoding: gzip
Accept-Language: en-US
Cookie: ASP.NET_SessionId=mm2uktupoluo3ex1mmnfxnb;
__RequestVerificationToken=x7jyfPSaQrVszXTnL3SIHrmWSuw2ebCPYwRiS6cK2D0oeerMVo46jGNCKh81cvLIrelkEISQYM-
UWUq2YBgOdAtdrt42ERXwEi8f_6X9sK1liL3IsH7PoL-i4i38H624BODvpI5AHd_fFCmkrJA8g2
Content-Length: 0

HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff

...
```

問題 2 / 2

目錄

偵測到隱藏目錄

嚴重性：	低
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
CVSS 3.1 評分：	3.7
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX
CVSS 4.0 評分：	6.3
URL：	https://prca.moenv.gov.tw/
實體：	home/ (Page)
風險：	有可能擷取網站檔案系統結構的相關資訊，其可能會幫助攻擊者對映網站
原因：	使用不安全的方式配置 Web 伺服器或應用程式伺服器
修正：	對禁止的資源發出「404 - 找不到」回應狀態碼，或將其完全移除

推論：此測試嘗試檢測伺服器上的隱藏目錄/檔案。回應狀態為 200 OK 或 403 Forbidden。狀態 200 表示測試成功檢索所要求的目錄/檔案的內容。狀態 403 表示它的存在，即使不允許存取。

原始測試回應：

```
...

Sec-Fetch-Dest: script
Referer: https://prca.moenv.gov.tw/
Accept-Encoding: gzip
Accept-Language: en-US
Cookie: ASP.NET_SessionId=mm2uktupoluoh3exlmmnfxnb;
__RequestVerificationToken=x7jyfPSaQrVszXTnL3SIHrmWSuw2ebCPYwRiS6cK2D0oeerMVo46jGNCKH8lcvLIrelkEISQYM-
UWUq2YBgOdAtdrt42ERXwEi8f_6X9sKlLiL3IsH7PoL-i4i38H624BODvpI5AHd_fFCmkrJA8g2
Content-Length: 0

HTTP/1.1 200 OK
Cache-Control: private,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: 0
Vary: Accept-Encoding
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff

...
```

低 在 CSP 中未強制執行腳本中的可信類型 ①

目錄

問題 1 / 1

目錄

在CSP中未強制執行腳本中的可信類型

嚴重性：	低
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
CVSS 3.1 評分：	3.7
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX
CVSS 4.0 評分：	6.3
URL：	https://prca.moenv.gov.tw/
實體：	prca.moenv.gov.tw (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置 有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等
原因：	不安全的 Web 應用程式設計或配置
修正：	配置正確值的Content-Security-Policy

推論：缺少需要信任類型的'script'

原始測試回應：

```
...
Accept-Language: en-US
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Referer: https://prca.moenv.gov.tw/
Host: prca.moenv.gov.tw
User-Agent: Mozilla/5.0 (Windows NT 6.2; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/100.0.4896.127 Safari/537.36
Content-Length: 0

HTTP/1.1 200 OK
Cache-Control: public,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/css; charset=utf-8
Expires: Tue, 29 Jun 2027 01:51:36 GMT,0
Last-Modified: Mon, 29 Jun 2026 01:51:36 GMT
Vary: User-Agent
Content-Security-Policy: default-src 'none'; object-src 'none'; base-uri 'none'; frame-ancestors 'none';
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
...
```

低 遺漏「Content-Security-Policy」標頭 1

目錄

問題 1 / 1

目錄

遺漏「Content-Security-Policy」標頭

嚴重性：	低
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
CVSS 3.1 評分：	3.7
CVSS 4.0 向量：	AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX
CVSS 4.0 評分：	6.3
URL：	https://prca.moenv.gov.tw/
實體：	prca.moenv.gov.tw (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置 有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等
原因：	不安全的 Web 應用程式設計或配置
修正：	配置伺服器利用安全原則使用 "Content-Security-Policy" 標頭

推論：AppScan 偵測到遺漏 Content-Security-Policy 回應標頭或包含不安全原則，這會增加各種跨網站注入攻擊的暴露風險
原始測試回應：

```
...

Sec-Fetch-Dest: script
Referer: https://prca.moenv.gov.tw/
Accept-Encoding: gzip
Accept-Language: en-US
Cookie: ASP.NET_SessionId=mm2uktupoluoh3exlmmnfxnb;
__RequestVerificationToken=x7jyfPSaQrVszXTnL3SIHrmWSuw2ebCPYwRiS6cK2D0oeerMVo46jGNCKH8lcvLIrelkEISQYM-
UWUq2YBgOdAtdrt42ERXwEi8f_6X9sKl1iL3IsH7PoL-i4i38H624BODvpI5AHd_fFCmkrJA8g2
Content-Length: 0

HTTP/1.1 200 OK
Cache-Control: no-cache,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: application/javascript
Expires: 0
Last-Modified: Fri, 30 Dec 2022 03:03:58 GMT
Accept-Ranges: bytes
ETag: "0a3185cfb1bd91:0"
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0

...
```

問題 1 / 1

目錄

SameSite 屬性未受限制的 Cookie

嚴重性：	參考資訊
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
CVSS 3.1 評分：	0.0
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N/E:X
CVSS 4.0 評分：	0
URL：	https://prca.moenv.gov.tw/
實體：	ASP.NET_SessionId (Cookie)
風險：	將 Cookie 限制為第一方，或是將相同網站環境定義設定為 Strict，藉此預防 Cookie 資訊洩漏。
原因：	SameSite 屬性未受限制的機密 Cookie
修正：	檢閱將 SameSite Cookie 屬性配置為建議值的可能解決方案

推論：回應包含 SameSite 屬性未受限制的機密 Cookie。如果可以的話，建議您將 SameSite 屬性設定為 Strict。不然的話，如果您避免使用 GET 要求，而且已設置完善的階段作業管理機制來徹底緩和 CSRF 風險，「Lax」值便已足夠。

原始回應

```
...
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer
'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:58:25 GMT
Content-Length: 35495
Set-Cookie: ASP.NET_SessionId=pfqcacdh031saleef44sku5z; path=/; secure; HttpOnly; SameSite=Lax
Set-Cookie:
_RequestVerificationToken=x37NJ8TlVCoC_W9Wv6ICN7rExWEefMzHFtlvA_Q3naDQX_e0B4bEtR6yb8UCfhICGI8nOUiGaXY6L2K80E
Yx0nXhr3_SBPTffgFOzyVAjcvDRnLVEjNvEU1HpRApvNOA8TI-AxuRuJCc2kJmOr-VMA2; path=/; secure; HttpOnly;
SameSite=Strict

<!DOCTYPE html>
<html lang="zh-Hant-TW">

...
```

問題 1 / 1

目錄

在CSP中發現瀏覽器忽略的指令

嚴重性：	參考資訊
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
CVSS 3.1 評分：	0.0
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N/EX
CVSS 4.0 評分：	0
URL：	https://prca.moenv.gov.tw/
實體：	prca.moenv.gov.tw (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置 有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等
原因：	不安全的 Web 應用程式設計或配置
修正：	配置正確值的Content-Security-Policy

推論：被瀏覽器忽略的指令或值

原始測試回應：

```
...
Accept-Language: en-US
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Referer: https://prca.moenv.gov.tw/
Host: prca.moenv.gov.tw
User-Agent: Mozilla/5.0 (Windows NT 6.2; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/100.0.4896.127
Safari/537.36
Content-Length: 0

HTTP/1.1 200 OK
Cache-Control: public,no-cache, no-store, must-revalidate, pre-check=0, post-check=0, max-age=0, s-maxage=0
Pragma: no-cache
Content-Type: text/css; charset=utf-8
Expires: Tue, 29 Jun 2027 01:51:36 GMT,0
Last-Modified: Mon, 29 Jun 2026 01:51:36 GMT
Vary: User-Agent
Content-Security-Policy: default-src 'none';script-src 'self' 'nonce-TqBW0yZvV8ToJ7d7g759ifv0sr1JZ2LcYbInKJKglg4=' 'strict-dynamic' https://www.google-analytics.com https://www.googletagmanager.com https://maps.googleapis.com https://api.tgos.tw;style-src 'self' 'nonce-TqBW0yZvV8ToJ7d7g759ifv0sr1JZ2LcYbInKJKglg4=' https://fonts.googleapis.com https://cdnjs.cloudflare.com https://api.tgos.tw https://map.tgos.tw; font-src 'self' data: https://cdnjs.cloudflare.com https://fonts.gstatic.com;connect-src 'self' https://www.google-analytics.com https://www.googletagmanager.com;img-src 'self' data: https://www.googletagmanager.com https://www.google-analytics.com;object-src 'none';base-uri 'none';frame-ancestors 'none';media-src 'none';frame-src 'none';child-src 'none';worker-src 'self';form-action 'self';manifest-src 'self';require-trusted-types-for 'script'; trusted-types default dompurify app-policy goog#html;
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin
Strict-Transport-Security: max-age=2592000
Feature-Policy: accelerometer 'none'; camera 'none'; geolocation 'none'; gyroscope 'none'; magnetometer 'none'; microphone 'none'; payment 'none'; usb 'none'
Date: Mon, 29 Jun 2026 01:51:36 GMT
Content-Length: 29135
```

...

問題 1 / 1

目錄

找到可能的伺服器路徑揭露型樣

嚴重性：	參考資訊
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
CVSS 3.1 評分：	0.0
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N/EX
CVSS 4.0 評分：	0
URL：	https://prca.moenv.gov.tw/bundles/jqueryval
實體：	jqueryval (Page)
風險：	有可能擷取 Web 伺服器安裝架構的絕對路徑，其可能會幫助攻擊者展開進一步攻擊，以及取得 Web 應用程式之檔案系統結構的相關資訊
原因：	未安裝協力廠商產品的最新修補程式或緊急修復程式
修正：	請下載您的 Web 伺服器或 Web 應用程式的相關安全修補程式。

推論：回應包含伺服器上的絕對路徑及/或檔名。

原始測試回應：

```
...
...&&"undefined"!==typeof t.validity?t.validity.badInput?"NaN":u.val():(i=e?
u.text():u.val(),"file"===f?"C:\fakepath\\"===i.substr(0,12)?i.substr(12):(r=i.lastIndexOf("/"),r>=0?
i.substr(r+1):(r=i.lastIndexOf...
```

問題 1 / 1

目錄

找到電子郵件位址型樣

嚴重性：	參考資訊
狀態：	待解決
CVSS 3.1 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
CVSS 3.1 評分：	0.0
CVSS 4.0 向量：	AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N/EX
CVSS 4.0 評分：	0
URL：	https://prca.moenv.gov.tw/PublicInfo/GetSearchResult
實體：	GetSearchResult (Page)
風險：	有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置
原因：	不安全的 Web 應用程式設計或配置
修正：	從網站移除電子郵件位址

推論：回應包含可能是專用的電子郵件位址。

原始測試回應：

```
...
  ],
  "DepType": "應變機構",
  "ServiceItem": "基本項目【災情評估與行動計畫研擬、區域劃分與危害偵檢及安全防護作業、熱區常壓容器緊急應變作業、人員除污作業、協助防止環境二次污染與災後復原】",
  "SepcialItem": "特殊項目【環境事故未知物鑑認應變作業、高壓容器應變作業、噸級以上之運輸容器應變作業、高風險毒性氣體應變作業(氯、氟、三氟化硼)、高風險易燃氣體應變作業(環氧乙烷、1,3-丁二烯、氯乙烯、氯乙烷、磷化氫)、高風險禁水性物質應變作業(三氯化磷、氰胺化鈣)"]",
  "ServiceCityName": "基隆市、新北市、臺北市、桃園市、新竹縣、新竹市、苗栗縣、臺中市、南投縣、彰化縣、雲林縣、嘉義縣、嘉義市、臺南市、高雄市、屏東縣、臺東縣、花蓮縣、宜蘭縣",
  "FirstArriveHumanResources": "4 人至 6 人",
  "ContinueArriveHumanResources": "6人",
  "ConnectorName": "陳憶萱",
  "ApplyDepTel": "049-2345613",
  "ApplyDepEmail": "cera.taiwan@gmail.com",
  "OpenInfo": "-"
}
]
```

如何修正

SameSite 屬性不安全、不適當或遺漏的 Cookie

目錄

原因：

SameSite 屬性不適當、不安全或遺漏的機密 Cookie

風險：

將 Cookie 限制為第一方或相同網站環境定義，藉此預防 Cookie 資訊洩漏。

如果沒有設置額外的保護措施（如反 CSRF 記號），攻擊者可以延伸為偽造跨網站要求 (CSRF) 攻擊。

SameSite 屬性控制跨網域要求的 Cookie 傳送方式。

屬性的值有三個：「Lax」、「Strict」或「None」。如果您使用「None」，網站可以建立與其他網站之間的跨網域 POST HTTP 要求，而瀏覽器會自動將 Cookie 新增到該要求中。

如果沒有設置額外的保護措施（如反 CSRF 記號），可能會引發偽造跨網站要求 (CSRF) 攻擊。

模式與其用法：

「Lax」模式：Cookie 只會連同最上層 GET 要求一同傳送。

「Strict」模式：即使使用者遵循其他網站的鏈結，Cookie 也不會連同任何跨網站用法一同傳送。

「None」模式：Cookie 將連同跨網站要求一同傳送。

擁有「Lax」或「None」的屬性必須設定「Secure」旗標，而且必須透過 https 傳輸。

範例 - Set-Cookie: key=value; SameSite=Lax;Secure

建議選項是將屬性設定為「Strict」。

範例 - Set-Cookie: key=value; SameSite=Strict

受影響的產品：

此問題可能會影響各種類型的產品。

修正建議：

一般

[1] 檢閱將 SameSite Cookie 屬性配置為建議值的可能解決方案。[2] 將 Cookie 限制為第一方或相同網站環境定義。

[3] 將 Cookie 的 SameSite 屬性設定為 Strict 並加以驗證，確保 Cookie 只能在第一方環境定義中傳送。

[4] 或者，如果您想要放鬆第一方環境定義的限制，請將 Cookie 的 SameSite 屬性設定為 Lax 並啟用 Secure 旗標，再透過 HTTPS 傳輸，同時加以驗證。

CWE：

1275

284

923

外部參照：

WASC 威脅分類：資訊洩漏

SameSite Cookie

加密的階段作業 (SSL) Cookie 中遺漏安全屬性

目錄

原因：

Web 應用程式會透過 SSL 傳送未受保護的 Cookie

風險：

有可能竊取在加密階段作業期間傳送的使用者和階段作業資訊 (Cookie)
在應用程式測試期間，偵測到在加密階段作業中，所測試的 Web 應用程式設定了不含 "secure" 屬性的 Cookie。
由於這個 Cookie 未包含 "secure" 屬性，因此，也可能在未加密的階段作業期間將它傳給網站。
任何以明碼傳給伺服器的 Cookie、階段作業記號或使用認證之類的資訊都可能被竊，稍後可用來盜用身分或使用模擬。
此外，若干隱私權法規指出，使用者認證之類的機密性資訊一律以加密方式傳給網站

受影響的產品：

這個問題可能會影響不同類型的產品

修正建議：

一般

基本上，Cookie 的唯一必要屬性是 "name" 欄位。
常見的選用屬性如下："comment"、"domain"、"path"，等等。
"secure" 屬性必須相應地設定，才能防止以未加密的方式來傳送 Cookie。
如需如何設定安全旗標的相關資訊，請前往以下鏈結，並參閱 OWASP " 安全屬性 " 題要
https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#secure-attribute
RFC 2965 指出：
「Secure 屬性（不含值）會指示使用者代理程式再次傳回這個 Cookie 時，都只用（未指定）安全方法來聯絡原始伺服器，以保護 Cookie 中之資訊的機密性與確實性。」
如需進一步的參照，請參閱「HTTP 狀態管理機制」RFC 2965，位置如下：
<http://www.ietf.org/rfc/rfc2965.txt>
如需使用「HTTP 狀態管理」的「最佳現行實務」，請參閱：
<http://tools.ietf.org/html/rfc2964>

CWE：

614
311
319

外部參照：

[Financial Privacy: The Gramm-Leach Bliley Act](#)
[Health Insurance Portability and Accountability Act \(HIPAA\)](#)
[Sarbanes-Oxley Act](#)
[California SB1386](#)

缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭

目錄

原因：

不安全的網頁應用程式編程或配置

風險：

嵌入跨來源資源（如腳本或圖像）而不設限制，會使您的網站容易受到不受信任的代碼執行和側信道洩漏的攻擊。攻擊者可以包含不使用正確 CORS 標頭的不透明第三方資源，即使沒有直接的腳本執行，也會創造安全漏洞。這種攻擊向量依賴於靜默地引入繞過驗證的第三方資源。
如果沒有 COEP，攻擊者可以嵌入不受信任的資源，繞過 CORS 的強制執行，從而導致數據洩漏，並破壞安全 API 所需的跨來源隔離。

受影響的產品：

此問題可能會影響不同類型的產品。

修正建議：

一般

將標頭 "Cross-Origin-Embedder-Policy: require-corp" 設置為強制僅加載啟用 CORS 或同源的資源。

CWE :
200

外部參照 :
OWASP 安全標頭專案 - COEP

缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭

[目錄](#)

原因 :
不安全的網頁應用程式編程或配置

風險 :
現代瀏覽器允許窗口和標籤頁相互交互，即使它們來自不同的來源。這種行為可能會使您的網站暴露於跨來源側信道攻擊，因為它允許惡意網站與您的網站共享瀏覽上下文。攻擊向量涉及攻擊者在新標籤頁或iframe中打開您的網站，並使用像'window.opener'這樣的共享引用。
在沒有 COOP 的情況下，惡意網站可以在新標籤頁中打開您的頁面，並利用共享的瀏覽上下文進行側信道攻擊，可能洩露跨來源數據，例如會話令牌或敏感內容。

受影響的產品 :
此問題可能影響不同類型的產品。

修正建議 :
一般

將標頭設置為 "Cross-Origin-Opener-Policy: same-origin"，以確保您的網站在一個單獨的瀏覽上下文組中運行，將其與其他來源隔離。

CWE :
200

外部參照 :
OWASP 安全標頭專案 - COOP

缺少或不安全的跨來源資源政策 (CORP) 標頭

[目錄](#)

原因 :
不安全的網頁應用程式編程或配置

風險 :
網頁應用程式通常提供靜態資源，例如圖像、腳本或 API，這些資源不應被其他網站嵌入或重用。若沒有保護，惡意網站可能會嵌入您的資源並提取敏感數據，有時甚至會利用計時攻擊或通過瀏覽器行為洩露元數據。這種情況發生在資源未受保護且可跨來源自由訪問時。
沒有 CORP，第三方網站可能會嵌入並濫用您的私人資源，從而導致數據洩漏或在已驗證的會話中進行搭載。

受影響的產品 :
此問題可能影響不同類型的產品。

修正建議 :
一般

將資源的「 Cross-Origin-Resource-Policy 」標頭設置為「 same-origin 」或「 same-site 」，以防止第三方未經授權的嵌入或重用。

CWE :
200

外部參照 :
OWASP 安全標頭專案 - CORP

偵測到隱藏目錄

目錄

原因 :
已使用不安全的方式配置 Web 伺服器或應用程式伺服器

風險 :
有可能擷取網站檔案系統結構的相關資訊，其可能會幫助攻擊者對映網站 Web 應用程式顯現了網站中的目錄。
雖然目錄並沒有列出它的內容，但這個資訊可以協助攻擊者對網站展開進一步的攻擊。
例如，知道目錄名稱之後，攻擊者便可以猜測它的內容類型，也許還能猜出其中的檔名或其下的子目錄，並嘗試存取它們。
內容的機密性愈高，這個問題也愈嚴重。

受影響的產品 :
這個問題可能會影響不同類型的產品。

修正建議 :

一般

如果不需要禁止的資源，請將它從網站中移除。
可能的話，請發出「404 - 找不到」回應狀態碼，而不是「403 - 禁止」。
這項變更會將網站的目錄模糊化，可以防止洩漏網站結構。

CWE :
200
497

在CSP中未強制執行腳本中的可信類型

目錄

原因 :
不安全的網頁應用程式編程或配置

風險 :
"Content-Security-Policy"標頭的設計是為了修改瀏覽器渲染頁面的方式，從而保護免受各種跨站點注入，包括跨站點腳本。設定標頭值的正確性非常重要，以免阻止網站的正常運作。
不使用Trusted Types可能會讓攻擊者注入腳本，結果，這增加了XSS漏洞的風險。

受影響的產品 :
這個問題可能會影響不同類型的產品。

修正建議：

一般

考慮使用 'require-trusted-types-for' 指令來防止基於 DOM 的 XSS 攻擊。
將「require-trusted-types-for 'script'」指令添加到您的 CSP 中，以強制執行腳本的受信類型。

CWE：

1032
79
693
830
1021

外部參照：

MDN 網頁文件 - 內容安全政策

遺漏「Content-Security-Policy」標頭

目錄

原因：

不安全的 Web 應用程式設計或配置

風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置

有可能讓無經驗而易受騙的使用者信以為真而提供機密資訊，例如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等

缺少 CSP 或設定不適當的值，可能會導致 Web 應用程式遭受 XSS、點擊劫持等攻擊。

「Content-Security-Policy」標頭的目的是在於修改瀏覽器呈現頁面的方式，進而預防各種跨網站注入攻擊，包括跨網站 跨網站指令碼。請務必設定正確的標頭值，避免網站運作不良。例如，如果將標頭設定為禁止執行行內 JavaScript，網站就不能在頁面中使用行內 JavaScript。

為了抵禦跨網站指令碼、跨框架 Scripting 及點擊劫持，請務必設定以下原則並提供適當的值：

「default-src」和「frame-ancestors」原則兩者，*或*「script-src」、「object-src」及「frame-ancestors」原則三者。

對於「default-src」、「script-src」及「object-src」，請避免「*」、「data:」、「unsafe-inline」或「unsafe-eval」這類不安全的值。

對於「frame-ancestors」，請避免「*」或「data:」這類不安全的值。

此外，對於「script-src」和「default-src」（「script-src」的後援指引），一般認為「self」是不安全的，應避免使用。

如需詳細資訊，請參考以下鏈結。

請注意，「Content-Security-Policy」包含四個不同的測試。有個一般測試會驗證「Content-Security-Policy」標頭是否正在使用中，其他三個測試會檢查「Frame-Ancestors」、「Object-Src」和「Script-Src」是否正確設定。

受影響的產品：

此問題可能會影響不同類型的產品

修正建議：

一般

設定您的伺服器以傳送「Content-Security-Policy」標頭。

建議您將 Content-Security-Policy 標頭設定為其指引的安全值，如下所示：

對於「default-src」和「script-src」，安全值包括「none」或 https://any.example.com。

對於「frame-ancestors」和「object-src」，預期的安全值包括「self」、「none」或 https://any.example.com 等。

「unsafe-inline」和「unsafe-eval」絕不能使用。使用暫時 / 雜湊只能是短期替代方案。

若為 Apache 伺服器，請參閱：

http://httpd.apache.org/docs/2.2/mod/mod_headers.html

若為 IIS 伺服器，請參閱：

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

若為 nginx 伺服器，請參閱：

http://nginx.org/en/docs/http/nginx_headers_module.html

CWE :
1032
79
693
830
1021

外部參照：

[幾個安全的標頭清單](#)

[「內容安全原則 \(Content Security Policy\)」的簡介](#)

[MDN web docs - Content-Security-Policy](#)

SameSite 屬性未受限制的 Cookie

[目錄](#)

原因：

SameSite 屬性與旗標未受限制的機密 Cookie

風險：

將 Cookie 限制為第一方，或是將相同網站環境定義設定為 Strict，藉此預防 Cookie 資訊洩漏

如果沒有設置額外的保護措施（如反 CSRF 記號），攻擊者可以延伸為偽造跨網站要求 (CSRF) 攻擊。

SameSite 屬性控制跨網域要求的 Cookie 傳送方式。

* Strict 模式是建議做法。即使使用者透過鏈結前往其他網站，Cookie 也不會連同任何跨網站用法一同傳送。

* 將 SameSite 屬性設定為「Strict」時，Cookie 只會在第一方環境定義中傳送，不會連同第三方網站起始的要求一同傳送。

* 範例 - Set-Cookie: key=value; SameSite=Strict

受影響的產品：

此問題可能會影響各種類型的產品。

修正建議：

一般

[1] 將 Cookie 限制為第一方環境定義。

[2] 將 Cookie 的 SameSite 屬性設定為 Strict，確保 Cookie 只能在第一方環境定義中傳送，同時加以驗證。

[3] 如果您避免使用 GET 要求，而且已設置完善的階段作業管理機制來徹底緩和 CSRF 風險，「Lax」值便已足夠。

CWE :
1275
923
284

外部參照：

[WASC 威脅分類：資訊洩漏](#)

[SameSite Cookie](#)

在CSP中發現瀏覽器忽略的指令

[目錄](#)

原因：

不安全的網頁應用程式編程或配置

風險：

"Content-Security-Policy"標頭的設計是為了修改瀏覽器渲染頁面的方式，從而保護免受各種跨站點注入，包括跨站點腳本。設定標頭值的正確性非常重要，以免阻止網站的正常運作。
某些指令（不支援、無效、已棄用、等等）可能會被瀏覽器忽略，導致配置錯誤，結果，安全政策可能無法按預期運作。

受影響的產品：

這個問題可能會影響不同類型的產品。

修正建議：

一般

將任何被忽略的值從您的CSP中移除：
在 CSP2 及以上版本中，當存在 nonce 或 hash 時，'unsafe-inline' 會被忽略。
在 CSP3 及以上版本中，當存在 'strict-dynamic' 時，任何主機來源或方案來源都會被忽略（例如 'self', http[s]:, https://example.com 等）。

CWE：

1032
79
693
830
1021

外部參照：

MDN 網頁文件 - 內容安全政策

找到可能的伺服器路徑揭露型樣

目錄

原因：

未安裝協力廠商產品最新的修補程式或緊急修復程式

風險：

攻擊者有可能擷取 Web 伺服器安裝架構的絕對路徑，並可能進一步展開攻擊，以及取得 Web 應用程式檔案系統結構的相關資訊
AppScan 偵測到含有檔案絕對路徑的回應。（例如 Windows 中的 c:\dir\file, 或 Unix 中的 /dir/file）
攻擊者可能會利用這項資訊在伺服器的目錄結構中取得機密資訊，並進一步利用機密資訊攻擊網站。

受影響的產品：

這個問題可能會影響不同類型的產品。

修正建議：

一般

以下方法能降低風險：
[1] 若應用程式本身含有弱點，請修正伺服器程式碼，使輸出值中不含有檔案位置。
[2] 若應用程式位於協力廠商產品內，請根據您在 Web 伺服器或 Web 應用程式所使用的協力廠商產品，下載相關安全修補程式。

CWE：

200
497

找到電子郵件位址型樣

原因：

不安全的 Web 應用程式設計或配置

風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置
Spambot 搜索網際網路網站，努力尋找電子郵件位址來建置傳送自發電子郵件（垃圾郵件）的郵寄清單。
AppScan 偵測到含有一或多個電子郵件位址的回應，可供不當運用，以便傳送垃圾郵件。
不但如此，找到的電子郵件位址也可能是私密電子郵件位址，不應供一般大眾來存取。

受影響的產品：

這個問題可能會影響不同類型的產品。

修正建議：

一般

從網站移除任何電子郵件位址，讓惡意使用者無法不當運用。

CWE：

359

200

311

外部參照：

Spambot 的定義（[維基百科](#)）